🕵️ Informe Ejecutivo de Investigación de Seguridad — Sprint 3

ID de Incidente:	INC-2026-03-22-001
Analista:	Jose Iván Arango Franco
Fecha:	18/09/2026

> 🚨 *Escenario: Viernes 03:00 AM — Alerta SIEM: usuario de Soporte Técnico conectado al Servidor BD de RRHH vía SMB desde estación de ingeniero de planta. Binarios nativos ejecutados: hostname.exe, whoami.exe. Sin malware. Solo tienes los logs.*

1. Resumen del Incidente

Escribe un párrafo ejecutivo (máximo 5 líneas): ¿Qué pasó? ¿Qué equipos estuvieron involucrados? ¿Quién inició la cadena de ataque? Sin detalles técnicos aquí.

detectamos que alguien se movió por dentro de la red buscando más acceso del que debería tener, usando herramientas que ya estaban instaladas en los sistemas, sin virus ni programas raros. La cadena arrancó, hasta donde pudimos rastrear, desde el equipo de un colaborador de Marketing pero al mirar con lupa encontramos señales de que el controlador de dominio y el servidor de backups también venían actuando raro desde antes, todavía no sabemos quién es el responsable ni cómo entró la primera vez.

2. Línea de Tiempo (Timeline) de la Evidencia

Reconstruye los hechos cronológicamente. Incluye tipo de log y Event ID (ej. Sysmon ID 1, Windows Security 4625). ⚠ *Requisito obligatorio: incluir Event IDs.*

Hora (UTC)	Host Origen	Host Destino	Evento / Log (Event ID)	¿Qué indica?
13:03:00	WKSTN-FIN-01	N/A (proceso local)	Sysmon EID 1 — chrome.exe	Navegación normal de m.garcia — línea base, sin hallazgo
13:16:00	SRV-DC-01	N/A (proceso local)	Sysmon EID 1 — explorer.exe (padre svchost.exe)	Bajo SYSTEM, sin logon humano que lo explique — anomalía más temprana de todo el caso
13:33:00	WKSTN-FIN-03	142.250.80.46	Sysmon EID 3	Conexión saliente — línea base, sin hallazgo
13:34:00	SRV-BACKUP-01	104.16.249.249	Sysmon EID 3 (puerto 8080)	Primer beacon hacia infraestructura CDN por puerto no estándar — anómalo
13:37:00	SRV-BACKUP-01	93.184.216.34	Sysmon EID 3 (puerto 8080)	Segundo beacon, mismo patrón — anómalo
13:49:00	WKSTN-IT-01	N/A (logon local)	Security EID 4624 (tipo 2)	Logon interactivo de d.admin — revisado, sin proceso sospechoso asociado
13:49:00	WKSTN-FIN-03	N/A (proceso local)	Sysmon EID 1 — Slack.exe	Actividad normal de r.santos — línea base
13:53:00	WKSTN-FIN-03	N/A (proceso local)	Sysmon EID 1 — outlook.exe	Línea base

13:57:00	SRV-DC-01	twitter.com (8.8.8.8)	Red — HTTP POST Log de red — sin Event ID nativo en la fuente	Inconsistencia entre url.full y url.path — dato dudoso, origen incierto
14:03:00	SRV-BACKUP-01	142.250.80.46	Sysmon EID 3	Posible continuación del canal de comunicación
14:05:12	WKSTN-MKT-04	SRV-APP-INT	Sysmon EID 1 — psexec.exe	Intento de movimiento lateral vía SMB con credenciales admin — confirmado
14:05:15	WKSTN-MKT-04	SRV-APP-INT	Security EID 4625	Logon fallido tipo 3, cuenta admin_local — confirmado, correlaciona con el PsExec
14:08:00	WKSTN-FIN-01	N/A (proceso local)	Sysmon EID 1 — chrome.exe	Línea base
14:08:45	WKSTN-MKT-04	N/A (proceso local)	Sysmon EID 1 — wmic.exe	Reconocimiento de cuentas locales tras el fallo — confirmado
14:14:00	SRV-DC-01	23.185.0.2	Sysmon EID 3	Conexión saliente adicional — anómalo
14:15:02	WKSTN-MKT-04	10.0.50.99	Firewall ALLOW (RDP 3389)	Pivote, tráfico permitido — resultado desconocido, sin telemetría en destino
14:15:06	WKSTN-MKT-04	10.0.50.99	Firewall DROP (SMB 445)	Intento de SMB bloqueado hacia el mismo objetivo
14:22:00	SRV-DC-01	mail.google.com (8.8.8.8)	Red — HTTP GET Log de red — sin Event ID nativo en la fuente	Nueva inconsistencia interna en campos — dato dudoso
14:26:00	SRV-DC-01	N/A (proceso local)	Sysmon EID 1 — chrome.exe (padre PID 751 no capturado)	Proceso padre nunca identificado — anómalo
14:30:00	WKSTN-FIN-01	SRV-FILE-01	Firewall ALLOW (RDP 3389)	Posible tercer punto de contacto de la misma campaña — reabierto
14:39:00	WKSTN-FIN-03	stackoverflow.com	Red — HTTP GET Log de red — sin Event ID nativo en la fuente	Línea base
14:46:00	SRV-BACKUP-01	151.101.1.140	Sysmon EID 3 (puerto 8080)	Tercer beacon — patrón exclusivo de este host en toda la red
14:51:00	WKSTN-FIN-03	N/A (loopback)	Firewall ALLOW Log de red — sin Event ID nativo en la fuente	Línea base, origen = destino
14:56:00	WKSTN-SALES-02	N/A (proceso local)	Sysmon EID 1 — explorer.exe	Línea base
15:03:00	SRV-WEB-01	N/A	Security EID 4624 (tipo 2)	Logon propio de SYSTEM — línea base
15:04:00	SRV-DC-01	aws.amazon.com (resuelve a IP de Google)	DNS query Log de red — sin Event ID nativo en la fuente	Inconsistencia en resolución DNS — sin explicación

15:06:00	WKSTN-ENG-01	N/A	Security EID 4624 (tipo 3)	Logon de red, logon.ip = host.ip — revisado, sin indicador de lateralidad
15:10:00	WKSTN-ENG-01	N/A	Security EID 4624 (tipo 2)	Logon interactivo 4 min después — revisado, sin proceso sospechoso
15:16:00	SRV-WEB-01	N/A	Security EID 4624 (tipo 2)	Logon propio de SYSTEM — línea base
15:24:00	WKSTN-HR-02	N/A	Security EID 4624 (tipo 10)	Logon RDP, origen = destino — línea base
15:28:00	SRV-BACKUP-01	N/A (proceso local)	Sysmon EID 1 — OneDrive.exe (padre PID 941 no capturado)	Proceso enmascarado como sincronización a la nube — anómalo, posible exfiltración

3. Hipótesis de Investigación (MITRE ATT&CK)

Relaciona cada hallazgo con fases de MITRE ATT&CK (ej. Initial Access, Execution, Discovery, Lateral Movement, Credential Access).

Fase MITRE ATT&CK	Evidencia en los logs	¿Qué significa?
Initial Access / Credential Access	No hay ningún log (en ningún host del dataset) anterior al primer evento anómalo detectado (SRV-DC-01, 13:16:00). Se buscó explícitamente actividad previa en WKSTN-MKT-04 (antes de 14:05:12), resultado: solo los mismos 4 logs ya conocidos, ninguno anterior. Se buscó también en SRV-DC-01 y SRV-BACKUP-01 el proceso padre de los binarios anómalos (PID 751 y PID 941 respectivamente): no existe en el índice.	Es el punto ciego más importante de toda la investigación: no sabemos cómo entró el actor a ninguno de los tres hosts de apoyo. La ausencia total de telemetría previa, en tres hosts distintos, el mismo día, no se trata como "sin hallazgo" sino como señal de riesgo. No se puede descartar phishing, credenciales robadas o compromiso previo no detectado por el SIEM.
Execution (LotL — binarios nativos)	(1) psexec.exe \\SRV-APP-INT -u admin -p [REDACTED] cmd.exe, ejecutado por m.perez en WKSTN-MKT-04 a las 14:05:12. (2) wmic.exe useraccount get name,sid, ejecutado por el mismo usuario en el mismo host a las 14:08:45. (3) chrome.exe ejecutado bajo cuenta SYSTEM en SRV-DC-01 a las 14:26:00, con proceso padre chrome.exe (PID 751) nunca capturado en el dataset. (4) OneDrive.exe ejecutado bajo cuenta SYSTEM en SRV-BACKUP-01 a las 15:28:00, con proceso padre	El actor no introdujo malware ni herramientas externas — usó exclusivamente binarios que ya venían instalados en Windows (PsExec, WMIC) y ejecutó software que simula procesos legítimos (Chrome, OneDrive) bajo una cuenta de servicio, en servidores donde ningún usuario humano inició sesión para justificarlo. Esta es la firma central de todo el caso: Living off the Land — cada binario, visto de forma aislada, es inofensivo; lo que lo vuelve sospechoso es el contexto en el que aparece (host, cuenta, ausencia de un padre legítimo).

	chrome.exe (PID 941) tampoco capturado.	
Discovery	wmic.exe useraccount get name,sid, ejecutado en WKSTN-MKT-04 a las 14:08:45, tres minutos y medio después del intento fallido de PsExec contra SRV-APP-INT.	Enumeración de cuentas locales del propio host comprometido. La secuencia temporal (fallo de autenticación → enumeración de cuentas) sugiere que el actor, tras no lograr acceso con la primera credencial, buscó alternativas válidas en el propio equipo antes de intentar un segundo objetivo — aunque no hay un log que confirme directamente que el resultado de este comando alimentó el siguiente paso.
Lateral Movement (SMB / Pass-the-Hash)	(1) Intento de autenticación tipo 3 (red) hacia SRV-APP-INT, EID 4625 (fallido), a las 14:05:15, generado por la ejecución de PsExec tres segundos antes. (2) Tráfico de red ALLOW hacia 10.0.50.99, puerto 3389 (RDP), a las 14:15:02, desde el mismo origen (WKSTN-MKT-04). (3) Tráfico de red DROP hacia el mismo destino, puerto 445 (SMB), a las 14:15:06. (4) Tráfico ALLOW de WKSTN-FIN-01 hacia SRV-FILE-01, puerto 3389 (RDP), a las 14:30:00 — descartado inicialmente por falta de correlación con m.perez, pero reabierto como posible tercer punto de la misma campaña bajo la hipótesis de presencia interna más amplia.	Dos intentos confirmados de moverse desde una estación de usuario hacia servidores internos usando protocolos administrativos estándar (SMB para PsExec, RDP como alternativa), más un tercer evento con el mismo patrón general que no puede descartarse con la evidencia disponible. El primer intento falló por credencial inválida (confirmado). El segundo generó tráfico permitido a nivel de red, pero el resultado real de autenticación es desconocido porque el host destino (10.0.50.99) no tiene ninguna telemetría propia — no se puede confirmar ni descartar que el actor haya obtenido acceso.
Command and Control	Tres conexiones salientes desde SRV-BACKUP-01: a las 13:34:00 hacia 104.16.249.249:8080, a las 13:37:00 hacia 93.184.216.34:8080, y a las 14:46:00 hacia 151.101.1.140:8080 — todas por el mismo puerto no estándar (8080), hacia tres IPs distintas pertenecientes a infraestructura de CDN (Cloudflare, Fastly, y un bloque histórico de Akamai/Edgecast), con volúmenes de datos pequeños y similares en cada conexión (entre 1 y 4 KB). Se confirmó, mediante búsqueda sin restricción de host en todo el índice, que estas son las únicas tres	El patrón (múltiples destinos, mismo puerto no estándar, volúmenes pequeños y recurrentes, espaciados en el tiempo) es consistente con beaconing de bajo perfil hacia un canal de comando y control, posiblemente camuflado usando infraestructura CDN legítima como fachada (domain fronting). La exclusividad de este patrón en un solo host —y precisamente el servidor de backups— es lo que elevó este hallazgo de "anomalía aislada" a "hilo central de la investigación".

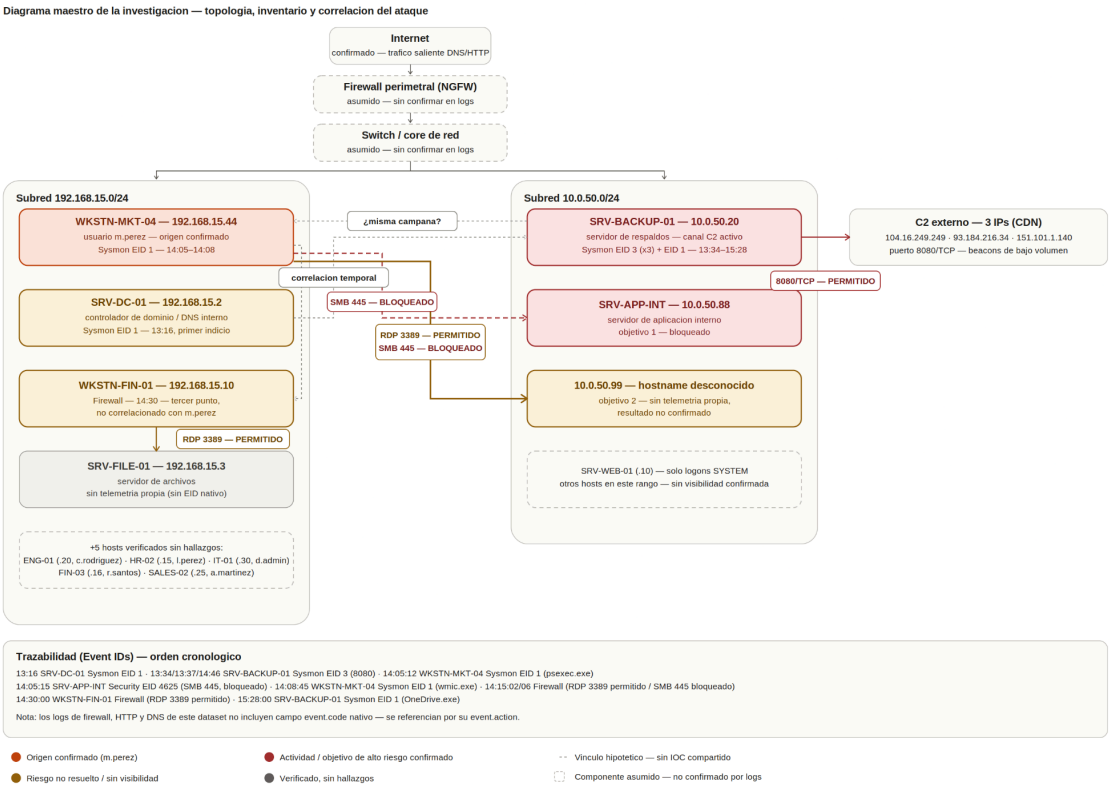
	conexiones al puerto 8080 en toda la red — ningún otro host, servidor ni estación de usuario, genera este tipo de tráfico.	
Defense Evasion (evaluado activamente, sin confirmar)	Búsqueda de Event ID 1102 (borrado del registro de auditoría de Windows) en todo el índice, sin restricción de host ni fecha: sin resultados. Búsqueda de cualquier log histórico —de cualquier tipo— para el host 10.0.50.99, sin restricción de fecha: sin resultados, ni antes ni después del incidente.	Se investigó de forma explícita la posibilidad de que la ausencia de telemetría en 10.0.50.99 se debiera a manipulación deliberada de logs por parte del actor, y no se encontró evidencia que la sostenga. La explicación más simple y consistente con la evidencia es falta de instrumentación (el host nunca estuvo configurado para enviar logs a este SIEM) — pero esto no se puede confirmar con certeza absoluta sin acceso forense directo al equipo, por lo que la posibilidad de manipulación queda evaluada y categorizada como más probable, no descartada por completo.
Exfiltration (hipótesis de mayor impacto, no confirmada)	OneDrive.exe, ejecutado bajo cuenta SYSTEM en SRV-BACKUP-01 a las 15:28:00, con proceso padre chrome.exe (PID 941) no capturado en el dataset — ocurre inmediatamente después de la tercera conexión de C2 identificada (14:46:00) en el mismo host.	El nombre del proceso simula un cliente legítimo de sincronización a la nube (OneDrive), ejecutándose en el único servidor de la red diseñado para contener una copia completa de los datos de toda la organización. No existe en los logs evidencia directa de una transferencia de archivos real (no hay eventos de acceso a archivos ni de tamaño de tráfico consistente con una exfiltración masiva), por lo que esto se mantiene como hipótesis de destino final de la campaña, con el mayor impacto potencial de todo el caso si llegara a confirmarse.

4. Diagrama de Red del Ataque

> ⚠️ *Requisito obligatorio. Dibuja el flujo del ataque: IPs, puertos (445 SMB / 3389 RDP), y si cada conexión fue exitosa o bloqueada. Puede ser a mano alzada o digital.*

Elementos mínimos: Estación del ingeniero → Servidor BD RRHH | Conexión SMB anómala | Sistemas afectados | IPs y puertos.

[Inserte o describe tu diagrama aquí — puede incluir una imagen pegada o una descripción textual del flujo: origen → destino, puerto, resultado (exitoso/bloqueado)]



5. Evaluación de Riesgo para el Negocio

Traduce el hallazgo técnico a impacto organizacional. ¿Qué pasaría si el atacante tiene éxito? Considera también riesgos legales (GDPR, LGPD, Ley 25.326 u otras aplicables).

Dimensión CIA	Impacto potencial	Riesgo legal / regulatorio
Confidencialidad	Riesgo crítico. No hay confirmación de acceso exitoso, pero el patrón apunta a dos activos con visibilidad total sobre el resto de la red: el controlador de dominio (que conoce cada cuenta y credencial del entorno) y el servidor de backups (que por definición contiene una copia completa de todo lo que la organización considera valioso). Si el canal de C2 detectado en SRV-BACKUP-01 es real, la pregunta deja de ser "¿qué servidor tiene datos sensibles?" y pasa a ser "¿qué NO tiene acceso ya el atacante?".	Bajo la Ley 1581 de 2012 (Colombia) y el Decreto 1377/2013, un indicio razonable de compromiso sobre sistemas con datos personales activa el deber de valorar notificación a la SIC y a los titulares, con multas de hasta 2.000 SMLMV solo por incumplir ese deber — independientemente de si se prueba exfiltración. Si hay titulares en la UE, el RGPD exige notificación en 72 horas desde el conocimiento razonable del incidente (ese plazo ya estaría corriendo). En Brasil aplicaría la LGPD (Ley 13.709/2018) con obligaciones equivalentes ante la ANPD; en Argentina, la Ley 25.326 exige medidas de seguridad adecuadas y responsabiliza al responsable del archivo ante su ausencia.
Disponibilidad	Riesgo bajo a la fecha. Ninguna técnica observada (PsExec, WMIC, beaconing) es destructiva por sí sola, y no hay evidencia de interrupción. Pero el patrón completo —canal de C2 persistente en el servidor de backups, seguido de un proceso que simula sincronización a la nube— es exactamente la fase de preparación de un ataque de ransomware: inutilizar o exfiltrar las copias de seguridad antes de cifrar el resto de la red, para que la organización no pueda restaurar.	Una interrupción operativa derivada de este vector, especialmente con clientes bajo SLA o en sectores regulados (financiero, salud), expone a reclamaciones contractuales directas y a obligaciones de reporte en cascada ante supervisores sectoriales (Superintendencia Financiera, Supersalud). Si se determina que los gaps de visibilidad ya documentados (10.0.50.99, SRV-FILE-01, ausencia de logs de firewall perimetral) constituyeron negligencia en medidas de seguridad razonables, esto agrava la responsabilidad frente a terceros más allá de la sanción regulatoria directa.
Integridad	Riesgo crítico. Un controlador de dominio con procesos no explicados bajo cuenta SYSTEM es un escenario donde no se puede garantizar que la relación de confianza de todo el dominio (membresías de grupo, políticas de contraseña, tickets Kerberos) siga siendo la que la organización cree que es. Sumado a la posible alteración de las copias de backup, la pregunta ya no es "¿pueden modificar un registro?" sino "¿podemos confiar en que lo que tenemos guardado hoy sea recuperable mañana?".	Si hay registros contables o tributarios en los sistemas alcanzables desde el DC (ya se identificaron múltiples estaciones de Finanzas en la misma red), la pérdida de garantía de integridad expone a la organización frente al Estatuto Tributario y las obligaciones de conservación de la DIAN, y a los administradores societarios frente al Código de Comercio si se demuestra negligencia en la custodia de la información financiera.

6. Estrategia de Remediación

Propón al menos dos controles accionables para mitigar este riesgo a futuro. Ej: segmentación de red, MFA, monitoreo de binarios nativos.

#	Control propuesto	¿Cómo ayuda?
1	Aislamiento y análisis forense inmediato de SRV-DC-01 y SRV-BACKUP-01, incluyendo una copia de verificación aislada de los backups más recientes	Responde a la hipótesis de mayor impacto de todo el caso, no a un hallazgo secundario. Si el canal en SRV-BACKUP-01 lleva tiempo activo, no se puede asumir que las copias actuales sean confiables para una restauración limpia — esto no puede esperar al resto del plan.
2	Bloqueo inmediato del tráfico hacia el puerto 8080 y las tres IPs de C2 identificadas, a nivel de firewall perimetral	Corta el canal de comunicación saliente detectado mientras se completa la investigación forense, sin esperar a confirmar su propósito exacto.
3	Auditoría de Kerberos y membresías de grupo en el dominio	No se puede descartar manipulación a nivel de confianza si el controlador de dominio estuvo expuesto — sin esta auditoría, cualquier otra remediación se construye sobre una base cuya integridad no está verificada.
4	Cierre de los gaps de visibilidad en 10.0.50.99, SRV-FILE-01, y despliegue de telemetría de red perimetral (firewall/switch)	Es la razón estructural por la que esta correlación casi no se detecta. Un atacante no necesita ser sigiloso donde nadie está mirando.
5	Segmentación de red y bloqueo de tráfico este-oeste (SMB/RDP directo usuario→servidor), con prioridad reforzada en aislar SRV-DC-01 y SRV-BACKUP-01 en una VLAN de máxima restricción	Es la causa raíz que permitió tanto el intento de PsExec como el canal externo: una estación de Marketing nunca debería tener ruta directa hacia esos dos activos.
6	LAPS y MFA en accesos administrativos y remotos	Elimina la reutilización de credenciales locales que hizo viable el intento de PsExec, y añade una segunda barrera incluso si una credencial válida es robada.
7	Activación del protocolo legal/DPO de inmediato, en paralelo a la investigación técnica, no como paso final	Los plazos de notificación regulatoria (72 horas bajo RGPD, deber de valorar notificación a la SIC bajo Ley 1581) se cuentan desde el conocimiento razonable de la sospecha, no desde la confirmación forense completa — esperar sería en sí mismo un incumplimiento.